INTI International College Penang **School of COMPUTING**

3+0 Bachelor of Science (Hons) in Computer Science, in collaboration with Coventry University, UK

3+0 Bachelor of Science (Hons) in Computing, in collaboration with Coventry University, UK

Coursework Cover Sheet

Section A - To be completed by the student

<table>
<tr><td colspan="2">Full Name: CHIN HUI ZHEN</td></tr>
<tr><td colspan="2">CU Student ID Number: 14196391</td></tr>
<tr><td colspan="2">Semester: August 2024</td></tr>
<tr><td colspan="2">Lecturer: R.K. KRISHNAMOORTHY
Email: <u>kmoorthy.ksamy@newinti.edu.my</u>
Extension: 345</td></tr>
<tr><td colspan="2">Module Code and Title: INT6005CEM SECURITY</td></tr>
<tr><td>Assignment No. / Title: Evaluation of Security System</td><td>Assignment Type: Individual
50% of Module Mark</td></tr>
<tr><td>Hand out date: 30th August 2024</td><td>Due date: 27th September 2024</td></tr>
<tr><td colspan="2">Penalties: NO late work will be accepted. If you are unable to submit coursework on time due toextenuating circumstances, you may be eligible for an extension. Please consult the lecturer.</td></tr>
<tr><td colspan="2">Declaration: I/we the undersigned confirm that I/we have read and agree to abide by the Universityregulations on plagiarism and cheating and Faculty coursework policies and procedures. I/we confirm that this piece of work is my/our own. I/we consent to appropriate storage of our work forplagiarism checking.

Signature(s):
 
Name: Chin Hui Zhen
Student ID: 14196391</td></tr>
</table>

Section B - To be completed by the module leader

Intended learning outcomes assessed by this work: 1. Critically evaluate a range of encryption and authentication methods for a given set ofrequirements of a selected system. 2. Utilize systematic knowledge to create secure environments at the host or networklevel of a selected system.		
Marking scheme	Max	Mar k
1. Report *Refer to the section on Marking Scheme on detailed breakdown.*	**100**	
Total	**100**	
Lecturer's Feedback		
Internal Moderator's Feedback		

TABLE OF CONTENTS

LIST OF TABLES v

LIST OF FIGURES vi

LIST OF ABBREVIATIONS vii

1.0 Introduction and System Overview 1

1.1 System Architecture and Potential Security Vulnerabilities of MyBSN 1

1.2 Importance of Encryption and Authentication for MyBSN 2

2.0 Security Requirement Analysis 3

2.1 Dependency on Phone Number for SMS and OTP 3

2.2 Lack of Multi-Factor Authentication (MFA) 4

2.3 Weak Password Requirements 5

2.4 Screen Recording 5

3.0 Encryption Authentication Evaluation 6

3.1 Encryption 6

3.2 Authentication 9

4.0 Recommendations and Implementation 11

4.1 Recommended Encryption and Authentication Methods 11

4.1.1 Encryption 11

4.1.2 Authentication 13

4.2 Security Issues Addressed 13

4.2.1 Encryption (RSA 3072-bit and ECC) 13

4.2.2 Authentication 14

4.3 Challenges, Risks and Emerging Security Framework 14

4.3.1 Challenges and Risks 14

4.3.2 Emerging Security Framework 15

5.0 Conclusion 15

5.1 Key Findings 15

5.2 Monitoring and Maintenance 15

5.3 Learning Outcomes/ Reflection 16

6.0 References.....17

7.0 Appendix

LIST OF TABLES

Table 1.1 Security Architecture 1
Table 1.2 Importance of Encryption and Authentication 2
Table 3.1 Effectiveness, Usability and Scalability of Authentication Methods 10
Table 4.1 Key Management (SSL, 2024) 11
Table 4.2 Challenges and Risks of Proposed Implementation 14

LIST OF FIGURES

Figure 1.1 MyBSN Features (BSN, 2024) (Store, 2024) 1
Figure 2.1 MyBSN Login Page (Personal Test) 4
Figure 3.1 SSL Test Report 6
Figure 3.2 SSL Test Report 7
Figure 3.3 SSL Test Report 8
Figure 3.4 SSL Test Report 9
Figure 4.1 TLS 1.2 Handshake (catchpoint, 2024) 12
Figure 4.2 TLS 1.3 Handshake (catchpoint, 2024) 12

LIST OF ABBREVIATIONS

GIRO	General Interbank Recurring Order
EPF	Employees Provident Fund
SMS	Short Message Service
OTP	One-Time Password
MFA	Multi-Factor Authentication
GDPR	General Data Protection Regulation
RSA	Rivest-Shamir-Adleman
SSL	Secure Sockets Layer
EV	Extended Validation
HTTPS	Hypertext Transfer Protocol Secure
TLS	Transport Layer Security
ECC	Elliptic Curve Cryptography
ECDH	Elliptic Curve Diffie-Hellman
ECDHE	Elliptic Curve Diffie-Hellman Ephemeral
HSM	Hardware Security Module
API	Application Programming Interface
MITM	Man-in-the-Middle

1.0 Introduction and System Overview

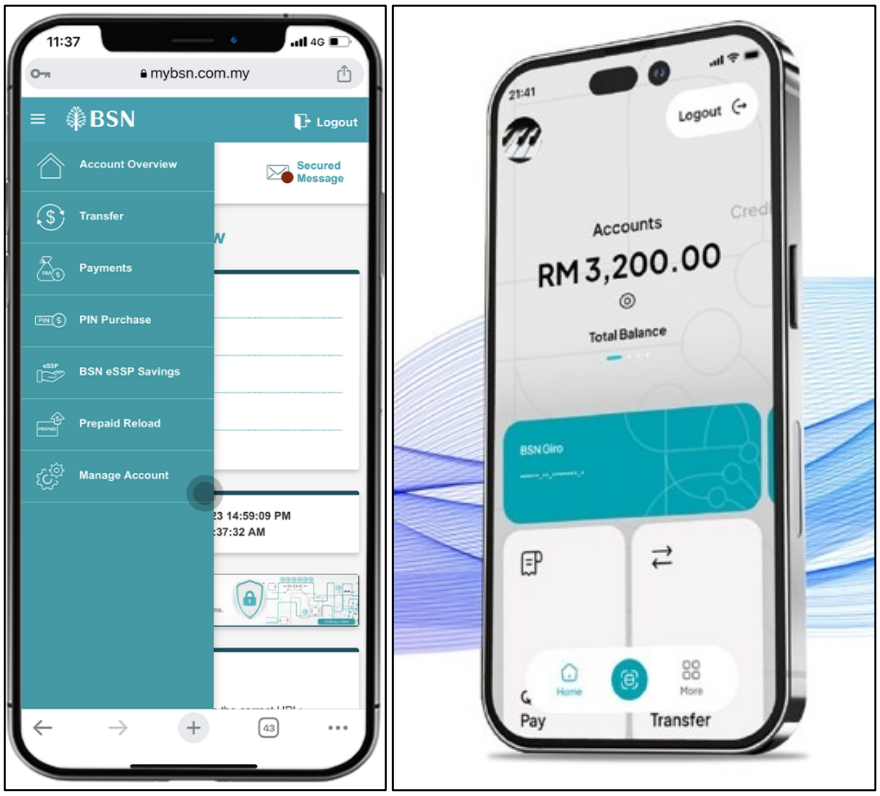


Figure 1.1 MyBSN Features *(BSN, 2024) (Store, 2024)*

MyBSN is Bank Simpanan Nasional's Internet banking service in Malaysia, which can be accessible through web browsers and mobile applications. It allows customers to track account balances, transfer funds through DuitNow, pay bills through JomPay, apply for loans and make credit card payments (Store, 2024). MyBSN also supports interbank GIRO for fund transfers, loan payments and payments to other banks' credit cards and EPF contributions (BSN, 2024).

1.1 System Architecture and Potential Security Vulnerabilities of MyBSN

The security architecture of MyBSN is divided into multiple layers as shown below.

Table 1.1 Security Architecture

Layer	Description
Authentication	Protection of username and password.
Encryption	Encryption of data exchanged using SSL protocol (BSN, 2024).
Certificates	Uses Verisign certificates that ensures the

	system is trusted and verified that it is interacting with legitimate server. It is WebTrust certified for maintaining high security standards (BSN, 2024).
Firewall	Acts as a barrier between the internal systems and external threats (BSN, 2024). It protects the financial system by scanning data packets in and out from a device or network to determine if they are safe or malicious (Cisco, 2024).
Antivirus Protection	Detects and prevents any illegitimate activities happening on their financial network systems.
System Reviews	Conducted by the development team regularly (BSN, 2024).

However, MyBSN may face vulnerabilities due to its dependency on phone numbers for SMS and OTP, insufficient multi-factor authentication and weak password requirements.

1.2 Importance of Encryption and Authentication for MyBSN

Table 1.2 shows the importance of encryption and authentication based on MyBSN's confidentiality, integrity and availability.

Table 1.2 Importance of Encryption and Authentication

	Confidentiality	**Integrity**	**Availability**
Encryption	Encryption protects and adds an extra layer of security to protect sensitive customer information such as bank account data, payment details and financial statements. This prevents unauthorized access	Encryption ensures that the financial data transferred between the customer and the bank is not modified during data transmission. This is because the encrypted data is difficult to alter	Encryption protects financial and personal data availability by making it unreadable to people without permissions. This prevents data from being stolen and exposed if any data breaches occur. For

	during the data transmission as the data has been converted to a long string that requires a decrypted key to decrypt the information.	without the correct decrypted key. Therefore, this ensures the encrypted data remains unchanged during storage.	example, it makes it harder for the attackers to access the banking accounts of customers during cyber-attacks.
Authentication	Authentication makes sure that only authorized users can access certain information by verifying their identity through usernames.	Authentication prevents unauthorized modifications from individuals, such as preventing malicious users from making fraudulent transactions or changing financial data without permission within the system.	Authentication gets user identity and gives them the appropriate level of access. It checks whether the user's credentials match those stored in the database. Users are normally identified with usernames or user ID. Multi-factor authentications add a layer of authentication to further confirming the identity of a user.

2.0 Security Requirement Analysis

2.1 Dependency on Phone Number for SMS and OTP

MyBSN depends on mobile devices to receive SMS and OTPs for authentication. If customers lost their device, they could reactivate their account on a new device only if they use the same phone number (BSN, 2023).

This causes the problem if attackers control the phone number through SIM swapping, as they can stop actions requested by the application including account deactivation. As a result, the attacker could access the account while the legitimate user remains locked out. This leads to potential account takeovers and unauthorized transactions if the attackers are faster to access

the application before the legitimate user notifies the helpdesk from the bank.

2.2 Lack of Multi-Factor Authentication (MFA)

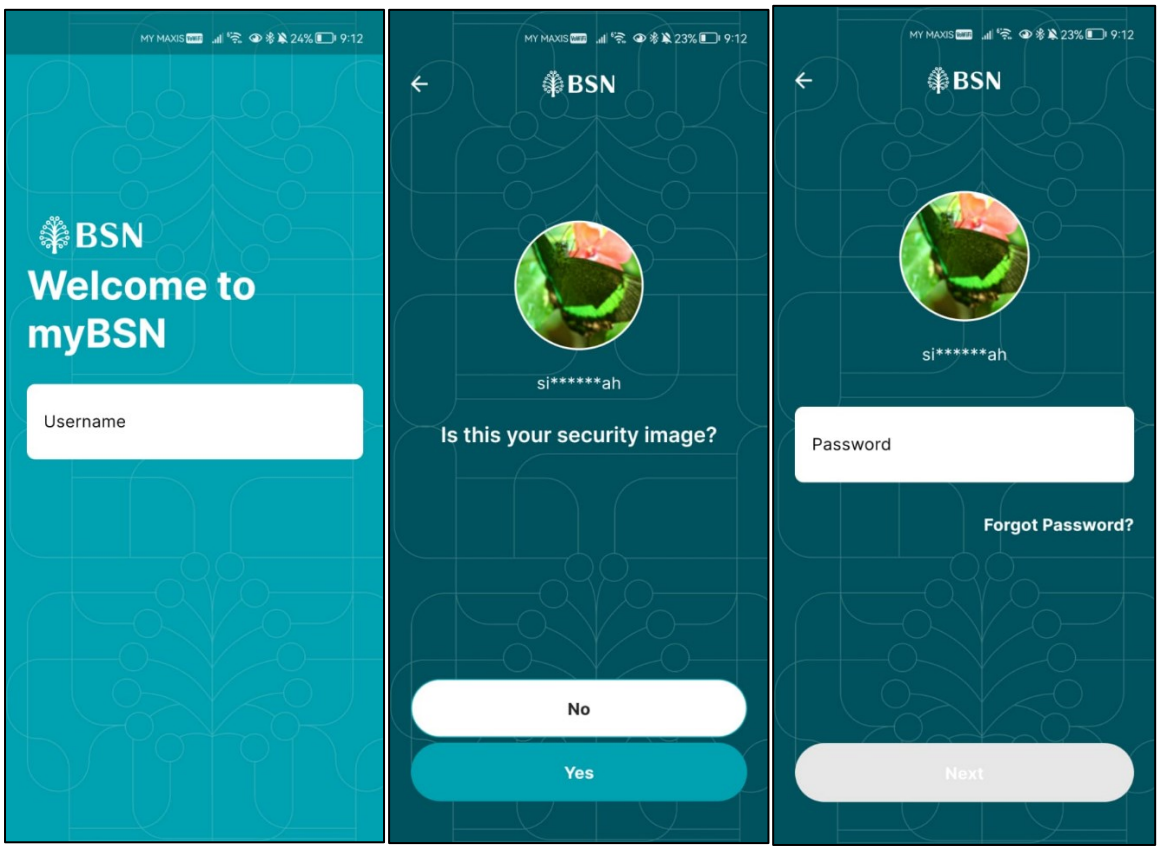


Figure 2.1 MyBSN Login Page (Personal Test)

In an online banking system, MFA must be implemented to prevent unauthorized access. It protects the account from being stolen even if the passwords are compromised. GDPR Article 32 emphasizes the importance of such security measures to protect personal and financial data.

Currently, MFA is weak on the login page, which only requires a username, security image verification and a password. This causes it to be vulnerable to credential stuffing. Currently, MFA is only implemented for transactions that require another authentication called BSNSecure (BSN, 2023).

Login page is the first line of defense of an account. Without MFA, especially in online banking where data sensitivity and confidentiality are high, it may lead to serious financial loss and data theft.

2.3 Weak Password Requirements

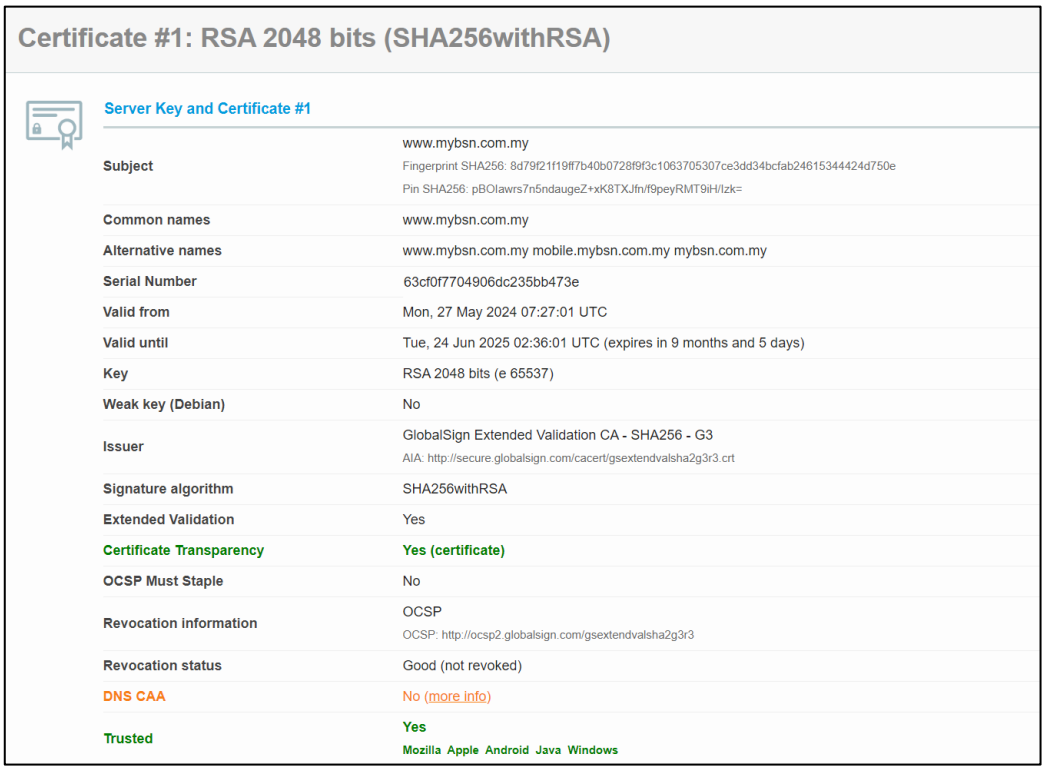
Password complexity is important in ensuring that accounts are not easily compromised. According to the security statement by MyBSN, the password must be 6 to 12 characters and consist of at least three of the following elements: uppercase/ lowercase alphabet, numbers or special characters (BSN, 2024). Therefore, it is not compulsory for the customers to create a difficult guessed password. Weak password requirements can put accounts at risk as attackers can use automated tools to guess and crack passwords for user authentication. The shorter the password length and the less password complexity make it easier for these tools to crack the password.

2.4 Screen Recording

Some banking applications like Maybank2u have implemented the detection of screen recording or sharing while customers are using the application. The Internet does not provide any information that MyBSN has implemented this feature, so it is considered as a possible vulnerability. Recording or sharing screens may expose sensitive banking information like account numbers, account balance or transaction histories. If the viewers have malicious intentions, they might capture the sensitive information and request or guide the person into performing certain actions that may expose more useful information, thus putting the account at risk (Maybank2u, 2024). It is recommended that MyBSN should block screen recording functionality while customers are using the application. If customers face any problems while using the application, they may contact the helpdesk instead of capturing the screen to consult others.

3.0 Encryption Authentication Evaluation

3.1 Encryption



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	www.mybsn.com.my Fingerprint SHA256: 8d79f21f19ff7b40b0728f9f3c1063705307ce3dd34bcfab24615344424d750e Pin SHA256: pBOIawrs7n5ndaugeZ+xK8TXJfn/f9peyRMT9iH/Izk=
Common names	www.mybsn.com.my
Alternative names	www.mybsn.com.my mobile.mybsn.com.my mybsn.com.my
Serial Number	63cf0f7704906dc235bb473e
Valid from	Mon, 27 May 2024 07:27:01 UTC
Valid until	Tue, 24 Jun 2025 02:36:01 UTC (expires in 9 months and 5 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	GlobalSign Extended Validation CA - SHA256 - G3 AIA: http://secure.globalsign.com/cacert/gsextendvalsha2g3r3.crt
Signature algorithm	SHA256withRSA
Extended Validation	Yes
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	OCSP OCSP: http://ocsp2.globalsign.com/gsextendvalsha2g3r3
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Figure 3.1 SSL Test Report

MyBSN was tested with SSL Lab to evaluate its encryption performance. It uses RSA2048-bit asymmetric encryption for data exchanged between the customer's browser and the server, such as login credentials and banking transactions data. However, there is no information available about data encryption in database servers. It is assumed that banking systems would encrypt data at rest.

RSA has a public (encrypt) and a private (decrypt) key. It divides the 2048-bit numbers into their prime components. The private key must be stored on the server in an encrypted unreadable format, whereas the public key is distributed in digital certificate as shown in figure below. Although the key is long, it takes longer processing time for key generation and it is possible to generate weak keys if the prime numbers chosen are too close.

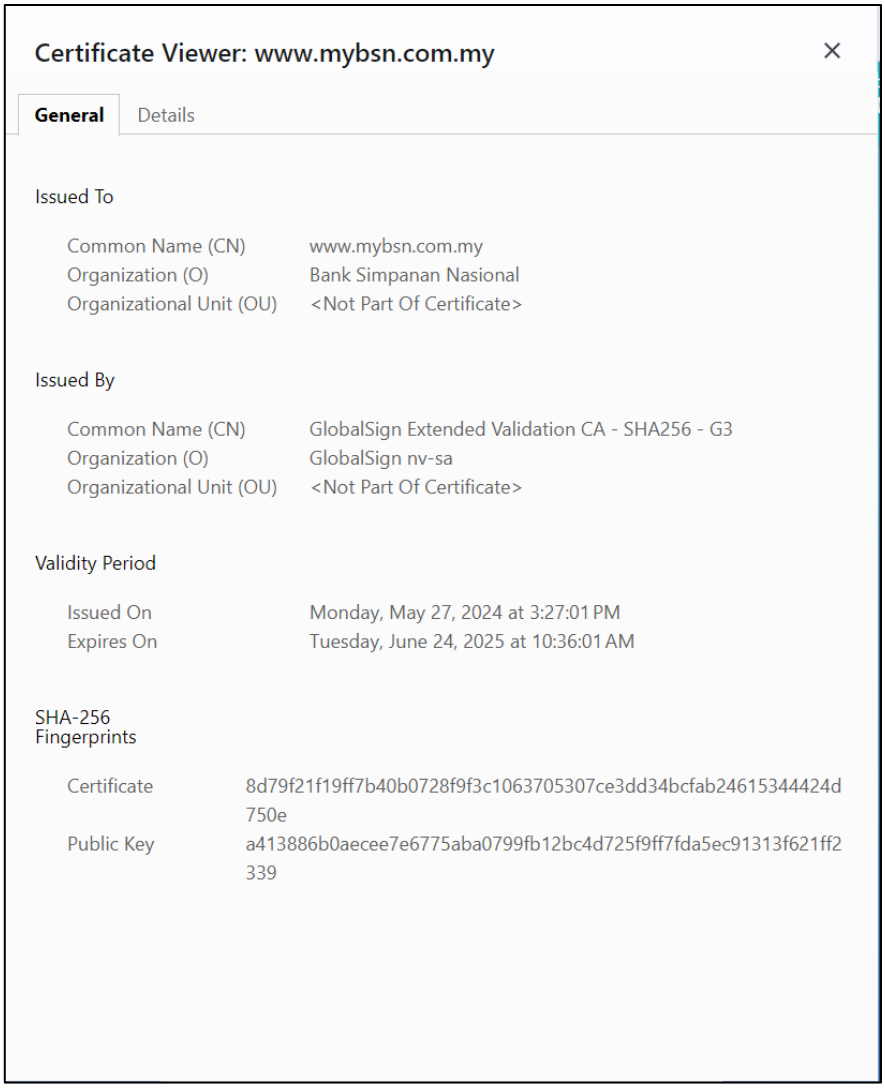


Figure 3.2 SSL Test Report

The system uses HTTPS with an Extended Validation (EV) certificate, which ensures good security and authentication through 16-point security check verification process (DigiCert, 2024). The certificate is valid until 24 June 2025, so it remains trusted by browsers and operating systems until its expiry date. Later, BSN needs to renew the certification to maintain secure connections continuously to the customers.

SHA-256 is a cryptographic hashing function used to create unique fingerprint of the certificate's data. Any small change to the certificate will alter the entire hash, causing the signature to change to the other side. The browser will keep comparing the changed signature with its original signature. If a mismatch is detected, the browser will terminate the certificate as invalid (Store, 2024). The customers will be alerted to stop the current process. At this point, all the encryption and authentication may be compromised.

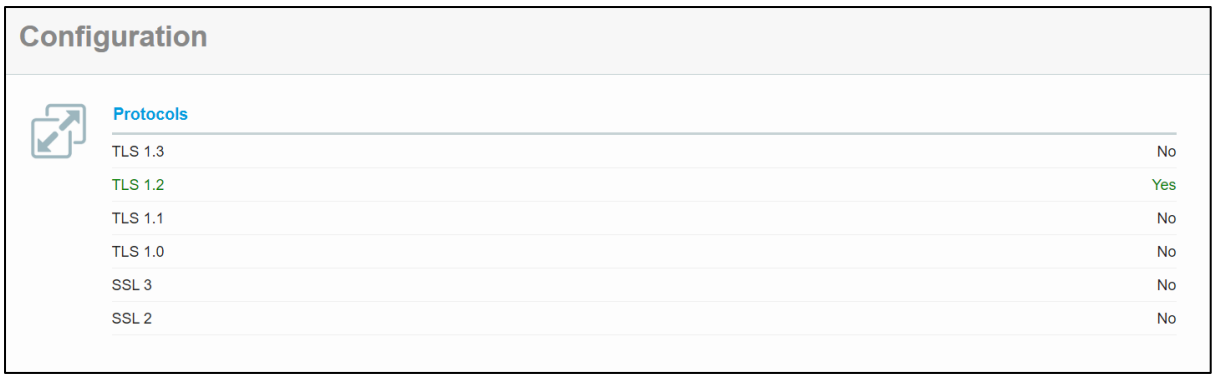


Figure 3.3 SSL Test Report

MyBSN server supports only TLS1.2 but does not support TLS1.3. Version 1.3 is the latest version of the TLS protocol, with more enhanced security features for data in transit. It is good that MyBSN does not support the older versions of TLS and SSL protocols, as they are considered vulnerable to various cyber-attacks.



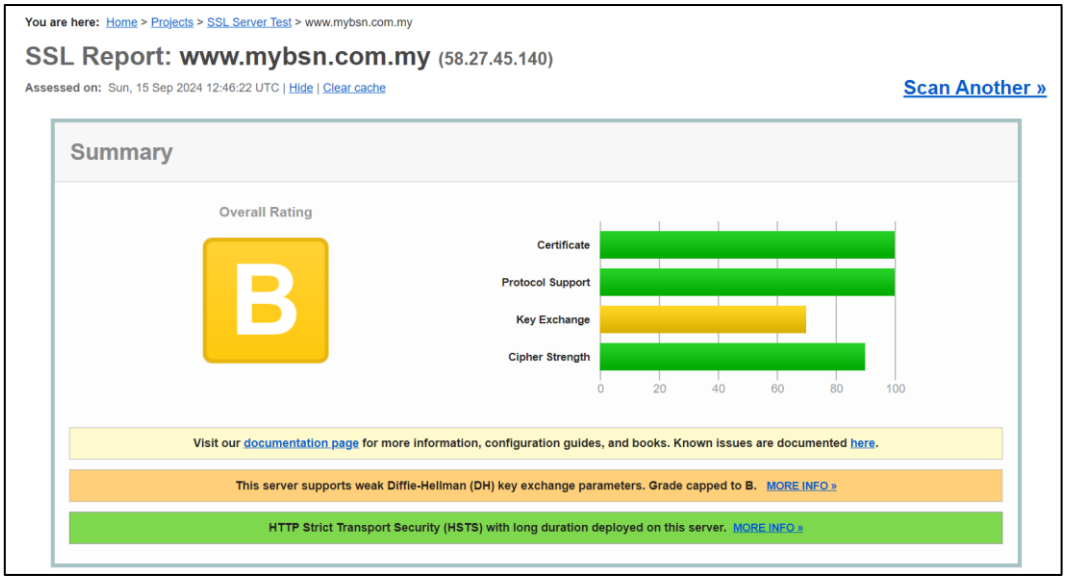


Figure 3.4 SSL Test Report

The cipher suites of MyBSN are considered weak, as it only includes four stronger protocols (green), like TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 and TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA256. GCM provides authenticated encryption with hashing. The rest of the protocols (red) are weak because they use CBC (Cipher Block Chaining) which has oracle attacks. The overall performance is Grade B. It is affected by the lower exchange rate of keys due to the use of weaker cipher suites protocols.

3.2 Authentication

For user registration, a username that is between 8 to 12 characters with both numbers and letters and the password requirement as explained earlier are required (BSN, 2024). During login, customers must enter their username, confirm the security image and passphrase and enter the password. The system validates user input from server side to prevent phishing. Only one login session is allowed per account, it terminates any multiple login attempts from other devices.

MFA only applies to transactions. Customers receive a push notification to approve or reject within 60 seconds. After that, the transaction is authenticated through BSNSecure as a second security layer. BSNSecure registration has a 12-hour cooling-off period before the app can be used. A 6-digit random number will be generated every 60 seconds for customers to enter it for transaction authentication (BSN, 2024). It reduces the dependency on SMS, but this only works if customers have enabled BSNSecure.

MyBSN system automatically logs customers out after a period of inactivity (BSN, 2024). This prevents unauthorized access if customers leave their session open for too long. It protects

sensitive and confidential information from being exposed to others if customers accidentally leave their device opened.

Overall, MyBSN has a satisfied security mechanism with good user experience. However, this comes with a trade-off in security, as attackers may steal or intercept communications between database servers and the customers, thus gaining access to any credentials.

Table 3.1 Effectiveness, Usability and Scalability of Authentication Methods

	Effectiveness	**Usability**	**Scalability**
Username and Password	Offers basic protection but can be vulnerable for phishing and credential stuffing attacks.	Commonly applied and easy to use for customers, but there is a possibility for passwords to be reused or weak.	Scalable, but needs better and robust password management policies for account protection.
Security Image and Passphrase	Adds an extra security layer protection for user identity verification.	It is easy if customers remember their chosen security image and passphrase, or else some customers may find it confusing.	Scalable, but needs to handle cases when the number of users grow, as there is a possibility for repeating choice of security image.
BSNSecure	Reduces dependence on SMS and OTP for transactions authentication.	Useful for transactions, but the 12-hour cooling-off period may frustrate customers if they need immediate approval.	Requires customers to enable it earlier before making transactions.
Push Notifications	Secure for transactions approvals but it is device-based and may be vulnerable to SIM swapping attacks.	Commonly used and easy to use for customers. 	Scalable, but the device may take some time to receive the notifications if there are large number of notifications are sent

			simultaneously.

4.0 Recommendations and Implementation

4.1 Recommended Encryption and Authentication Methods

4.1.1 Encryption

Currently, MyBSN uses RSA2048-bit asymmetric encryption for network-based data exchange.

Recommendation with Performance Impacts

It is recommended to use RSA3072-bit for signing digital certificates and ECC for key exchange. It is not hybrid but a separate role to each method. ECC can solve the prime number selection in RSA. It uses ECDH or ECDHE as protocols for key exchange, allowing key exchange over a channel by using elliptic curves algorithm, whereas RSA factors large numbers into their prime factors by choosing two large prime numbers (p and q) to generate a key pair. Therefore, ECC uses less memory with shorter keys and offers similar cryptographic strength to RSA, thus suitable for reducing memory and processing time in MyBSN.

Key Management

Table 4.1 shows the key management recommendations.

Table 4.1 Key Management *(SSL, 2024)*

Key Storage	Stores key securely using Hardware Security Module (HSM) with access control to protect from unauthorized access.
Key Generation	Creates new keys using strong cryptographic algorithms such as RSA and ECC.
Key Distribution	Uses TLS for key delivery, injects into applications and encrypts while at rest. Public keys can be shared through Certificate Authorities, whereas private keys must be stored securely and only distributed to authorized users.

Key Revocation	When the key is no longer in use, it must be revoked properly. For destroyed keys, cryptographic techniques can be used to prevent key reconstruction.

Protocols

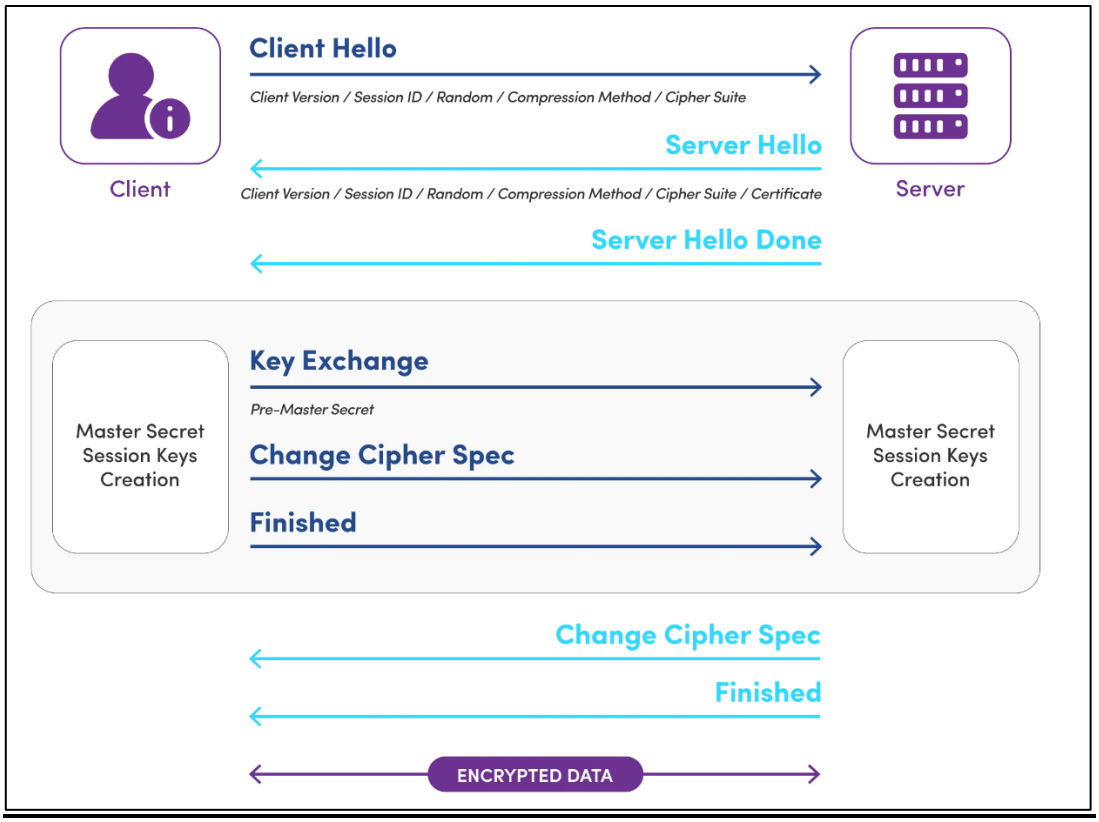


Figure 4.1 TLS 1.2 Handshake (catchpoint, 2024)

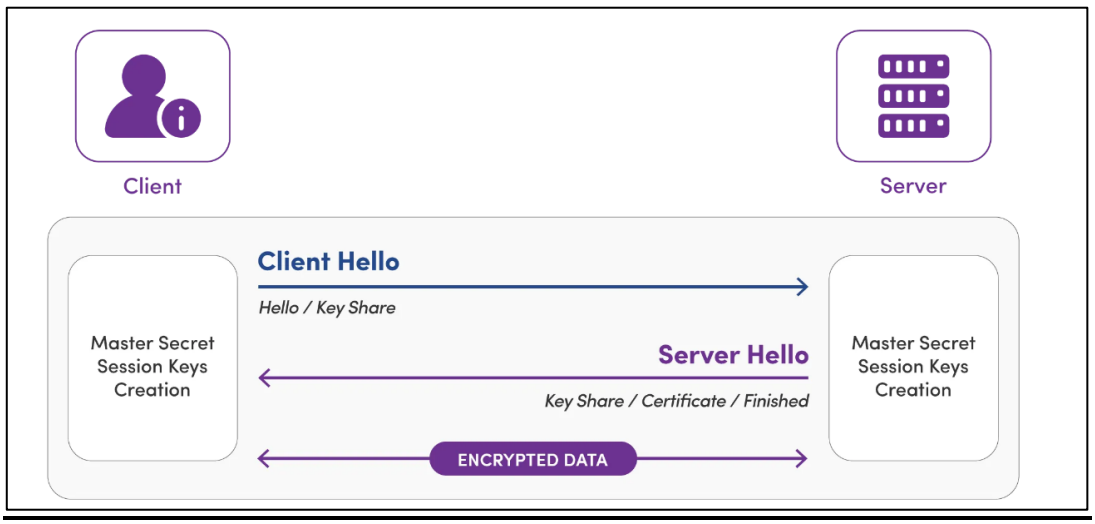


Figure 4.2 TLS 1.3 Handshake (catchpoint, 2024)

TLS1.3 should be used for secure communication on MyBSN, as its current use of TLS1.2 affects performance. TLS1.3 supports more secure cipher suites and reduces handshake to single round-trip as shown in figures above. It reduces the setup time by half and improves system performance and user experience with faster HTTPS connections. It launches session quickly like web pages and API calls (Cloudflare, 2024).

4.1.2 Authentication

MyBSN should enhance MFA by making biometric authentication like fingerprint or face recognition login compulsory instead of optional. It can strengthen security, as biometrics are unique and difficult to replicate (Descope, 2023). Currently, fingerprint login is an alternative option if customers forget their password. Additionally, reducing dependency on phone numbers for authentication would address the risks of SIM swapping or MITM attacks. Instead, MyBSN should consider the use of biometric recognition, authentication apps (Google Authenticator) or email-based verification (Campillo, 2024). Partnering with mobile carriers to detect SIM swap activities could further enhance security.

MyBSN should also enforce a stronger password policy by requiring at least 8 to 12 characters with a combination of all uppercase, lowercase, numbers and special characters (Microsoft, 2024). This strengthens the password requirements as long and complex passwords can protect the bank accounts and keep the information safe.

For transaction authentication, BSNSecure should be automatically enabled for all customers. This directly adds an extra security layer without requiring manual activation, so that all customers' transactions will be authenticated again by BSNSecure.

4.2 Security Issues Addressed

4.2.1 Encryption (RSA 3072-bit and ECC)

RSA 2048-bit is considered unbreakable with regular computers and commonly used in banks and governments for data security (Sharma, 2023). However, it may become vulnerable to quantum computing (SSL, 2024). RSA's key strength can be weakened if prime factors p and q are too close (Podobnik, 2022). ECC does not depend on prime factorization but uses discrete mathematical logarithms in elliptic curve equations. The logarithm problem is more complex and harder to solve than prime numbers in RSA (Sectigo, 2021). Furthermore, TLS1.3 uses cipher suites with Perfect Forward Secrecy (PFS) that prevents attackers from decrypting the past or future communications if they compromise a long-term key (Aken,

2024).

4.2.2 Authentication

MFA reduces dependency on username, password, security images and passphrase for login authentication. Relying on these credentials makes accounts vulnerable as they can be easily accessed once attackers compromise the database. Stronger alternatives such as biometrics offer better protection as fingerprints or faces cannot be replicated easily. It is also the same goes to using phone numbers alone for account activation or deactivation. Also, a stronger password policy would increase security as it is harder for attackers to crack. Finally, enabling BSNSecure automatically ensures consistent transaction protection. This avoids incidents where customers may forget or be confused about enabling it.

4.3 Challenges, Risks and Emerging Security Framework

4.3.1 Challenges and Risks

Table 4.2 shows the possible challenges and risks related to proposed implementation.

Table 4.2 Challenges and Risks of Proposed Implementation

	Explanations
User Experience	Implementing MFA or stronger password policy may frustrate some customers as they need to do changes compulsory due to privacy concerns.
Key Management Complexity	Managing cryptographic keys across different platforms and services can be difficult especially in MyBSN mobile and web applications. The need for secure storage, timely key generation, distribution and proper revocation even increases complexity in aspects of operation. The developers need to customize the code to fulfill the changes.
Quantum Computing Threats	As mentioned earlier, it is possible that RSA-based encryption could be vulnerable using quantum computing. However, quantum computers are still in the early stages of

	development, thus providing sufficient time for the developers to implement robust security measures.
Performance	Implementing stronger encryption methods such as both RSA 3072-bit and ECC may slow down MyBSN's services. Balancing security with performance is somehow challenging, especially for mobile applications.

4.3.2 Emerging Security Framework

Zero trust architecture can be implemented across encryption and authentication in MyBSN. It assumes the network to be hostile and checks every request based on access policy (NCSC, 2021). The model follows least privilege concept which grants users and devices only the permission they need to perform their actions (Sans, 2023).

In MyBSN, zero trust architecture can enhance both encryption and authentication. For encryption, data in transit and at rest would be secured using strong encryption standards. This ensures that the data cannot be read without correct decryption keys even in the event of an attack. For authentication, MFA such as implementation of biometric recognition can be used to require customers to provide additional information of user identity, further confirming the identity and strengthening the account access security.

5.0 Conclusion

5.1 Key Findings

Overall, the security measures in MyBSN are satisfied. As a banking system, it has implemented several robust security features for user data protection in aspects of encryption and authentication. To further ensuring the confidentiality, integrity and availability of data, the use of both RSA and ECC encryptions in digital signatures and key management respectively can be implemented to improve the performance and security enhancement of MyBSN. Also, authentication can be improved by implementing MFA, strong password policy and auto BSNSecure functionality.

5.2 Monitoring and Maintenance

Monitoring firewall logs and configurations can track performance, blocked traffic and any bypassed rules, with alerts for unusual activity reminders (checkmk, 2024). IDS detects

suspicious network activities (Fortinet, 2024). IPS works with firewall and IDS to respond automatically to real-time threats (TechImpact, 2023).

MyBSN's applications, web and database servers should be updated regularly with the latest security patches to overcome bugs and vulnerabilities. Daily automated data backup must be conducted to ensure data availability during data loss or corruption. MyBSN should prepare an incident response plan to manage potential security breaches, with recovery steps based on each scenario. Penetration testing can be done to identify vulnerabilities. Finally, regular updates and security checks for MFA are required to ensure they work correctly across all user accounts.

5.3 Learning Outcomes/ Reflection

In this assignment, I evaluated various encryption and authentication methods for MyBSN, gaining insights into the strengths and weaknesses of each security feature. I learned to analyze and recommend appropriate methods based on system requirements. This process improves my knowledge of asymmetric encryption and MFA while considering the performance and security risks at the same time.

I learned to use systematic knowledge in creating secure environments for MyBSN by recommending both RSA and ECC encryptions, TLS1.3 protocol, key management strategies and firewalls with IDS and IPS implementations. I also realized the importance of having proper key management in maintaining encryption effectiveness.

6.0 References

Aken, S., 2024. *Rethinking network and security monitoring in the age of TLS 1.3.* [Online]
Available at: https://www.securitymagazine.com/articles/100585-rethinking-network-and-security-monitoring-in-the-age-of-tls-13#:~:text=TLS%201.3%20requires%20only%20cipher%20suites%20that,the%20private%20encryption%20keys%20to%20read%20all
[Accessed 21 September 2024].

BSN, 2023. *DuitNow.* [Online]
Available at: https://www.bsn.com.my/page/duitnow
[Accessed 14 September 2024].

BSN, 2023. *myBSN Mobile Application.* [Online]
Available at: https://www.bsn.com.my/cms/upload/pdf/customer_care/mybsn-mobile-app/faq.pdf
[Accessed 15 September 2024].

BSN, 2024. *BSNSecure.* [Online]
Available at: https://www.bsn.com.my/page/BSNSecure
[Accessed 20 September 2024].

BSN, 2024. *myBSN Products & Services.* [Online]
Available at:
https://www.bsn.com.my/page/myBSNProductsServices?csrt=2769686300327824350
[Accessed 14 September 2024].

BSN, 2024. *myBSN Under 18 Years Old.* [Online]
Available at: https://www.bsn.com.my/page/myBSNUnder18?csrt=14739116319160118000
[Accessed 14 September 2024].

BSN, 2024. *Safe Switch.* [Online]
Available at: https://www.bsn.com.my/page/SafeSwitch
[Accessed 14 September 2024].

BSN, 2024. *Security Statement.* [Online]
Available at: https://www.bsn.com.my/page/security-statement
[Accessed 14 September 2024].

Campillo, R., 2024. *What is Multifactor Authentication (MFA) or Two Factor Authentication (2FA).* [Online]
Available at: https://www.mobbeel.com/en/blog/what-is-multi-factor-authentication-mfa-or-two-factor-authentication-2fa/
[Accessed 15 September 2024].

catchpoint, 2024. *TLS 1.2 vs. 1.3—Handshake, Performance, and Other Improvements.* [Online]
Available at: https://www.catchpoint.com/http2-vs-http3/tls1-2-vs-1-3#:~:text=The%20TLS%201.2%20requires%20two,parameters%20into%20one%20round%20trip.
[Accessed 23 September 2024].

checkmk, 2024. *What is a firewall?.* [Online]
Available at: https://checkmk.com/guides/firewall-monitoring#:~:text=Firewall%20log%20monitoring%20is%20the%20practice%20of,if%20any%20rules%20are%20not%20being%20triggered.
[Accessed 21 September 2024].

Cisco, 2024. *What is a firewall?.* [Online]
Available at: https://www.cisco.com/site/us/en/learn/topics/security/what-is-a-firewall.html#:~:text=practices%20for%20firewalls-,A%20primer%20on%20firewalls,%2C%20URL%20filtering%2C%20and%20more.
[Accessed 14 September 2024].

Cloudflare, 2024. *Why use TLS 1.3?.* [Online]
Available at: https://www.cloudflare.com/learning/ssl/why-use-tls-1.3/#:~:text=What%20are%20the%20advantages%20of,less%20vulnerable%20to%20cyber%20attacks.
[Accessed 21 September 2024].

Descope, 2023. *Biometric Fingerprint Authentication Explained.* [Online]
Available at: https://www.descope.com/learn/post/fingerprint-authentication
[Accessed 15 September 2024].

DigiCert, 2024. *What is an Extended Validation (EV) SSL certificate?.* [Online]
Available at: https://www.digicert.com/faq/public-trust-and-certificates/what-is-an-extended-validation-ev-ssl-certificate
[Accessed 18 September 2024].

Entrust, 2024. *Understanding Post-Quantum.* [Online]
Available at: https://www.entrust.com/resources/learn/post-quantum-cryptography#:~:text=Also%20known%20as%20%22quantum%2Dresistant,operational%20quantum%20computers%20by%202030.
[Accessed 21 September 2024].

Fortinet, 2024. *https://www.fortinet.com/resources/cyberglossary/intrusion-detection-system#:~:text=An%20intrusion%20detection%20system%20(IDS)%20is%20an,it%20detects%20any%20security%20risks%20and%20threats..* [Online]
Available at: https://www.fortinet.com/resources/cyberglossary/intrusion-detection-system#:~:text=An%20intrusion%20detection%20system%20(IDS)%20is%20an,it%20detects%20any%20security%20risks%20and%20threats.
[Accessed 21 September 2024].

Incognia, 2024. *What is a SIM Swap attack? [Why fast detection is important].* [Online]
Available at: https://incognia.com/the-authentication-reference/what-is-sim-swap-attack-and-why-fast-detection-is-important
[Accessed 15 September 2024].

Maybank2u, 2024. *Screen sharing and using your MAE app at the same time may expose sensitive banking information.* [Online]
Available at: https://www.maybank2u.com.my/maybank2u/malaysia/en/personal/security-enhancement/screen-sharing.page
[Accessed 15 September 2024].

Microsoft, 2024. *Create and use strong passwords.* [Online]
Available at: https://support.microsoft.com/en-us/windows/create-and-use-strong-passwords-c5cebb49-8c53-4f5e-2bc4-fe357ca048eb#:~:text=At%20least%2012%20characters%20long,phrase%20like%20%226MonkeysRLooking%5E%22.
[Accessed 15 September 2024].

NCSC, 2021. *Zero trust architecture design principles.* [Online]
Available at: https://www.ncsc.gov.uk/collection/zero-trust-architecture/introduction-to-zero-trust#:~:text=A%20zero%20trust%20architecture%20is,a%20good%20place%20to%20start.
[Accessed 21 September 2024].

Podobnik, T., 2022. *Vulnerabilities of RSA.* [Online]
Available at: https://cloudchirp.medium.com/how-to-choose-values-for-the-rsa-key-pair-

bcd587f36e5c#:~:text=Not%20only%20that%20prime%20numbers%20for%20RSA%20should%20be%20chosen,a%20the%20key%20generation%20process.
[Accessed 21 September 2024].

Sans, 2023. *What is Zero Trust Architecture?.* [Online]
Available at: https://www.sans.org/blog/what-is-zero-trust-architecture/
[Accessed 21 September 2024].

Sectigo, 2021. *What are the differences between RSA, DSA, and ECC encryption algorithms?.* [Online]
Available at: https://www.sectigo.com/resource-library/rsa-vs-dsa-vs-ecc-encryption#:~:text=ECC%20encryption%20is%20based%20on,approach%20enhances%20your%20enterprise%20security.
[Accessed 21 September 2024].

Sharma, D., 2023. *Chinese researchers claim they can break 2048-bit RSA using quantum computers, entire tech world at risk.* [Online]
Available at: https://www.indiatoday.in/technology/news/story/chinese-researchers-claim-they-can-break-2048-bit-rsa-using-quantum-computers-entire-tech-world-at-risk-2318133-2023-01-06
[Accessed 21 September 2024].

SSL, 2024. *Key Management Best Practices: A Practical Guide.* [Online]
Available at: https://www.ssl.com/article/key-management-best-practices-a-practical-guide/
[Accessed 21 September 2024].

Store, A., 2024. *myBSN.* [Online]
Available at: https://apps.apple.com/my/app/mybsn/id6449446936
[Accessed 14 September 2024].

Store, T. S., 2024. *Explained: What Is a SHA256 SSL Certificate?.* [Online]
Available at: https://comodosslstore.com/resources/what-is-a-sha256-ssl-certificate/
[Accessed 18 September 2024].

TechImpact, 2023. *IPS vs IDS: What's the Difference and Why It Matters.* [Online]
Available at: https://techimpact.org/news/ips-vs-ids-whats-difference-and-why-it-matters#:~:text=What%20is%20IPS?,traffic%20flows%20along%20that%20path.
[Accessed 21 September 2024].

7.0 Appendix

MyBSN Official Online Banking Website

https://www.mybsn.com.my/mybsn/login/login.do

SSL Lab Test

https://www.ssllabs.com/ssltest/analyze.html?d=www.mybsn.com.my&latest

Functionalities with Security Features of MyBSN

MyBSN supports DuitNow payments including QR code payments, fund transfer and receival. Customers are required to perform settings in their MyBSN account to enable DuitNow feature using the DuitNow ID (BSN, 2023). By having this, merchants can display their DuitNow QR code at the store to receive payments from customers.

In aspects of security, MyBSN integrates with a self-service security feature called BSN Safe Switch to block access if customers suspect their accounts have been compromised or scammed. This protects the funds and money saved and prevents unauthorized transactions going on in the accounts (BSN, 2024).

For banking accounts under 18 years old (13 to 17 years old), MyKad (identity card) and BSN card and BSN account application form are required for the children to open an internet banking account. After the registration online, customers are required to visit the nearest BSN branch or contact the helpdesk to activate the online account. The actions that can be performed in this account are limited to a default limit of RM 50 to maximum limit of RM 100 for fund transfer, DuitNow payments, FPX banking, pin purchase and prepaid reload (BSN, 2024). These are the security settings to protect the children's accounts from overspending and falling into traps of scamming.

Explanations of SIM Swapping

Term	Explanations	Use Case in Online Banking
SIM Swapping	It is an attack where the attacker transfers a phone number from a victim's SIM card (legitimate user) to his SIM card (Incognia, 2024). This means the takeover of the account ownership.	After the phone number is taken over, the attacker may reset the account password or login credentials on the victim's MyBSN account. He will receive the SMS-based OTP

		authentication sent to his phone. Then, he can conduct unauthorized activity using that account, including transferring money from the victim's account to a fraudulent account.

Plagiarism Check

